

Information Security Management System Manual

Veltrixa ApS

Document ID	ISMS-001	Version	1.0
Owner	ISMS Owner	Approver	CEO
Effective date	26 July 2026	Next review	26 July 2027
Classification	Internal / Portfolio	Status	Approved for portfolio use

Portfolio note. This document is an illustrative ISMS artefact for the fictional company Veltrixa ApS. It demonstrates ISO/IEC 27001:2022 implementation logic; it is not evidence of certification or live operational performance.

1. Purpose and use of this manual

This manual describes how Veltrixa ApS establishes, operates, evaluates and continually improves its Information Security Management System (ISMS). It is the system-level document: it explains what the organization does and points to the controlled documents and records that define how activities are performed and demonstrate their results.

The ISMS is designed around ISO/IEC 27001:2022 clauses 4–10 and applies the Plan–Do–Check–Act cycle. The order and separation of documents are governance choices, not additional requirements of the standard.

2. Document architecture

The following controlled information forms one coherent ISMS. The current approved version is identified in the document register.

ID	Document	Purpose	Owner
ISMS-001	ISMS Manual	Defines the management system and links its controlled information.	ISMS Owner
ISMS-002	ISMS Scope	Defines boundaries, interfaces, inclusions and exclusions.	ISMS Owner
POL-001	Information Security Policy	States management direction and security principles.	CEO
ISMS-RA-001	Risk Assessment and Treatment Methodology	Defines repeatable risk identification, scoring and treatment.	ISMS Owner
REG-RR-001	Information Security Risk Register	Records assessed risks, owners, controls and residual ratings.	ISMS Owner

ID	Document	Purpose	Owner
ISMS-SOA-001	Statement of Applicability	Records applicability, justification and implementation status for all Annex A controls.	ISMS Owner
PLAN-RTP-001	Risk Treatment Plan	Tracks approved treatment actions, owners, deadlines and evidence.	ISMS Owner
PLAN-OBJ-001	Information Security Objectives and Monitoring Plan	Defines measurable objectives, metrics and review cadence.	ISMS Owner
AUD-001	Internal Audit Programme and Report	Plans and records an illustrative internal ISMS audit.	Internal Auditor
REC-MRM-001	Management Review Minutes	Records required management review inputs, decisions and actions.	CEO
REG-CAR-001	Corrective Action Register	Tracks nonconformities, root causes, actions and effectiveness reviews.	ISMS Owner

3. Context of the organization (Clause 4)

3.1 Internal and external issues

Veltrixa is a fictional Danish B2B SaaS provider offering an AI-assisted cloud document-classification service. Relevant internal issues include a small cross-functional workforce, dependence on cloud infrastructure, rapid product change, remote working, limited segregation capacity and the need to balance delivery speed with control consistency.

Relevant external issues include GDPR and contractual security commitments, customer assurance expectations, evolving cyber threats, reliance on cloud and software suppliers, competition for skilled personnel and changes to technology or regulatory requirements. The ISMS Owner reviews these issues at least annually and when significant change occurs.

3.2 Interested parties and requirements

Interested party	Relevant need or expectation	How addressed
Customers	Confidentiality, availability, transparent incident handling and contractual compliance.	Security controls, supplier governance, incident process, service monitoring.
Data subjects	Lawful and secure handling of personal data.	Privacy governance, access restriction, retention and security controls.
Employees and contractors	Clear responsibilities, usable rules, training and secure tools.	Policies, role descriptions, onboarding, awareness and support.
Regulators and authorities	Compliance with applicable legal and regulatory requirements.	Compliance register, privacy controls, evidence retention and reporting.
Suppliers	Clear security obligations and proportionate assurance activity.	Due diligence, contracts, monitoring and change review.
Owners and management	Risk visibility, resilience and sustainable customer trust.	Risk register, objectives, audit, management review and improvement.

3.3 Scope and boundaries

The approved scope, boundaries, interfaces and exclusions are maintained in ISMS-002 – ISMS Scope. The scope covers the people, processes and technology used to develop, operate and support Veltrixa’s SaaS service. No ISO/IEC 27001 clause 4–10 requirement is excluded.

3.4 ISMS processes

Veltrixa establishes, implements, maintains and continually improves the ISMS through documented governance, risk management, control operation, competence and awareness, monitoring, audit, management review and corrective action. Process owners retain evidence proportionate to the risk and purpose of each process.

4. Leadership (Clause 5)

4.1 Leadership and commitment

- The CEO remains accountable for ISMS effectiveness and approves the scope, policy, risk acceptance and resources.
- The ISMS Owner coordinates the system, reports performance and ensures required processes interact effectively.
- Control owners implement and operate assigned controls and retain appropriate evidence.
- All personnel follow applicable policies, complete required training and report suspected events promptly.

4.2 Information security policy

Management direction, commitments and high-level principles are defined in POL-001 – Information Security Policy. The policy is communicated during onboarding, remains accessible to personnel and is reviewed at least annually.

4.3 Roles, responsibilities and authorities

Role	Core ISMS responsibility
CEO	Accountability, policy approval, resources, risk acceptance and management review.
ISMS Owner	ISMS coordination, risk process, document control, performance reporting and improvement tracking.
Engineering Manager	Secure development, change control, application security and remediation.
DevOps Lead	Cloud configuration, logging, monitoring, backup, resilience and vulnerability operations.
People Operations	Screening, contractual responsibilities, awareness, joiner–mover–leaver controls.
System and risk owners	Risk decisions, control operation, evidence and timely escalation.
All personnel	Policy compliance, protection of assets and immediate event reporting.

5. Planning (Clause 6)

5.1 Risks and opportunities

Information security risks are identified, analysed, evaluated and treated using ISMS-RA-001. Results are maintained in REG-RR-001. Selected Annex A controls, including exclusions and their justification, are recorded in ISMS-SOA-001. Approved actions are tracked in PLAN-RTP-001.

ISMS-level opportunities, such as automation of evidence collection, improved supplier assurance or better security metrics, are recorded as improvement actions when they can increase system effectiveness.

5.2 Information security objectives

Measurable objectives, owners, targets, measurement methods and review cadence are maintained in PLAN-OBJ-001. Performance is reviewed quarterly and forms an input to management review.

6. Support (Clause 7)

6.1 Resources and competence

Management determines and provides personnel, technology, time and budget needed to operate the ISMS. Competence requirements are defined for relevant roles. Evidence of education, training, experience or assessment is retained where appropriate.

6.2 Awareness and communication

Personnel are made aware of the policy, their contribution to ISMS effectiveness, relevant threats, reporting routes and consequences of nonconformity. Veltrixa defines what will be communicated, when, by whom, to whom and through which channel, considering confidentiality and legal obligations.

6.3 Control of documented information

- Each controlled document has an owner, identifier, version, approval, effective date, classification and review date.
- Changes are reviewed and approved before issue; obsolete versions are prevented from unintended use and retained only where needed.
- Access is restricted according to classification and business need; integrity and availability are protected.
- Records are retained for defined periods and remain traceable to the activity they evidence.
- External documents needed by the ISMS, including laws, contracts and standards, are identified and controlled.

7. Operation (Clause 8)

7.1 Operational planning and control

Control owners plan, implement and monitor security processes against defined criteria. Planned changes are controlled and unintended changes are reviewed for adverse consequences. Outsourced processes and suppliers are governed through documented requirements, due diligence and monitoring.

7.2 Risk assessment and treatment

The risk assessment is reviewed at least annually and after significant change, major incident, material supplier change or emergence of a significant threat. Treatment actions are approved by risk owners. Residual risks above tolerance require CEO acceptance or further treatment.

Related documents: ISMS-RA-001; REG-RR-001; ISMS-SOA-001; PLAN-RTP-001.

8. Performance evaluation (Clause 9)

8.1 Monitoring, measurement, analysis and evaluation

Veltrixa monitors objective achievement, control performance, incidents, vulnerabilities, supplier issues, training completion, risk treatment and corrective actions. Measures specify what is monitored, method, frequency, responsibility, analysis and reporting. Results are retained as records.

8.2 Internal audit

A risk-based audit programme evaluates conformity with Veltrixa's requirements and ISO/IEC 27001:2022, and whether the ISMS is effectively implemented and maintained. Audit scope, criteria, methods, responsibilities and reporting are defined in AUD-001. Auditors are selected to preserve objectivity and impartiality.

8.3 Management review

Top management reviews the ISMS at least annually and following significant change. Inputs include previous actions, changes in context and requirements, performance trends, nonconformities, monitoring results, audit results, objective achievement, interested-party feedback, risk status and improvement opportunities. Decisions and actions are retained in REC-MRM-001.

9. Improvement (Clause 10)

9.1 Nonconformity and corrective action

Veltrixa reacts to nonconformities, controls and corrects them, addresses consequences, evaluates root cause and recurrence, implements required action and reviews effectiveness. REG-CAR-001 records ownership, due dates, evidence and effectiveness conclusions.

9.2 Continual improvement

The suitability, adequacy and effectiveness of the ISMS are improved through analysis of risks, performance data, audit results, incidents, management decisions, feedback and corrective actions.